

8-3-1: Examining Zero Trust Architecture

At the end of this episode, I will be able to:

1. Identify and explain the fundamental of Zero Trust Architecture, given a scenario.

Learner Objective: *Identify and explain the fundamental of Zero Trust Architecture, given a scenario.*

Description: In this episode, the learner will examine Zero Trust Architecture or ZTA. We will explore the fundamental components and principles of Zero Trust Architecture.

- What is Zero Trust Architecture?
 - o A security model that requires strict identity verification for every person and device trying to access resources.
 - o Historical context/example
 - ♠ North-to-south = traditional perimeter-based security
 - ♠ East-to-west = traffic beyond the firewall always requires authentication.
 - ♠ Increase need in hybrid cloud (both NTS and ETW security)
 - o Based on the ZTA principle "Never Trust, Always Verify"
- What are the fundamentals of Zero Trust
 - o ZTA vs. Traditional Security - a static security model vs. a ZTA model where dynamically dispersed security.
 - o Network Segmentation - Example of segmenting a corporate network into HR, finance, and operations, each with separate access controls.
 - o Continuous Monitoring - Scenario of a system that continuously checks a user's behavior against their profile, flagging anomalies.
- What is Policy-Based Authentication?
 - o Modern identity verification - multifactor authentication using a password, a mobile device, and a fingerprint.
 - o Dynamic authentication - example: access permissions change based on location, time, or device security status.
 - o Adaptive risk assessment - a user's risk level is assessed based on unusual download patterns or access requests.
- What is authorization like in Zero Trust?
 - o Role-Based Access Control (RBAC) - traditional authorization example: an employee accessing resources based on their role.
 - o Attribute-Based Access Control (ABAC) - example: an employee access a resource based their attributes like location, time of day.
 - o Real-time authorization - example: a user's access to sensitive data is revoked the moment their role changes in the HR system.
 - o Continuous Re-validation - example: periodic checks where a user is prompted to re-authenticate at random intervals during a session.
- What is Least Privilege Access?
 - o Principle of Least Privilege - example: employees are given access only to the resources necessary for their job.
 - o Just-In-Time and Just-Enough-Access - example: employees are given temporary access grant to a system for maintenance purposes, and restricting access to only what is needed.
 - o Mitigating risks - Explain how least privilege can prevent a malware infection from spreading beyond its entry point.
- What are some challenges and potential ways to overcome them?
 - o

- Transition challenges - example: a legacy enterprise might face in shifting to ZTA, like legacy systems compatibility.
 - o Best Practices - example: starting with a small, critical area of the network and gradually expanding ZTA principles across the organization.
-

- Additional Resources:
 - o If applicable